NACL first-match reasoning

Local 07 · 45–60 minute add-on after the AWS VPC lesson

PRIMARY LESSON

AWS Academy

Cloud Security Foundations Module 4 · VPC security controls

COURSE ADD-ON

Local 07

Trace subnet rules, return traffic and the NAT route.

Use the assigned AWS module and lab first; work on only your assigned Local Part.

The question: which rule decides?

RECALL

Security group

Instance-level, stateful, allow rules only.

FOCUS

Network ACL

Subnet-level, stateless, ordered allow and deny rules.

EVIDENCE

Explain the path

Name the first matching rule for both an intended and an unwanted packet.

AWS Module 4 supplies the VPC baseline · This add-on supplies Local 07 reasoning.

One request, two filters

01

Client

203.0.113.55 → port 443

→

02

Subnet NACL

Check inbound rule by number

→

03

Security group

Check allowed inbound flow

→

04

Server

Return traffic takes the reverse path

Security group

Stateful: an allowed request permits its response without a separate outbound rule.

NACL

Stateless: check the return packet against outbound rules too.

A successful inbound rule does not prove the stateless return path works.

Trace the first match

Rule	Action	Source CIDR	Port
#80	ALLOW	10.0.1.0/24	5432
#100	DENY	0.0.0.0/0	5432

Trace the packet

10.0.1.25 — Matches #80 → allow

203.0.113.55 — Skips #80; matches #100 → deny

Read from the lowest rule number. Stop after the first match.

A visible deny may never run

Rule	Action	Source CIDR	Port
#70	ALLOW	0.0.0.0/0	5432
#90	DENY	0.0.0.0/0	5432

Trace the packet

External source — Matches broad #70 → allow

Internal source — Also matches #70 → allow

Narrow the earlier allow to the intended CIDR; keep it before the catch-all deny.

What the NAT gateway changes

01

Private instance

Initiates an update request

→

02

Private route

Default route → NAT gateway

→

03

Public subnet

NAT gateway → internet gateway

→

04

Internet

Response returns to the initiated flow

Allowed direction

The private instance can initiate outbound traffic when routes and rules permit.

Boundary

An unsolicited inbound internet connection is not forwarded to that private instance by NAT.

The NAT gateway sits in a public subnet; its users stay in a private subnet.

Use one method for every answer

1 · IDENTIFY

Packet and boundary

State source IP, destination port, direction and the control being checked.

2 · WALK

Rule order

Read each NACL rule in ascending order; stop at the first match.

3 · VERIFY

Before and after

Compare vulnerable and fixed results, including an intended path that still works.

C5R1: Part 2 · C5R2: Part 1 · Submit only your assigned Part in Classroom.